

See discussions, stats, and author profiles for this publication at: <https://www.researchgate.net/publication/359004207>

MITRE ATT&CK and D3FEND Framework MITRE ATT&CK : Design and Philosophy

Technical Report · March 2022

DOI: 10.13140/RG.2.2.34885.73440

CITATIONS

0

READS

506

1 author:

[Shreyash Sharma](#)

International Institute of Information Technology

17 PUBLICATIONS 0 CITATIONS

SEE PROFILE

MITRE ATT&CK and D3FEND Framework

MITRE ATT&CK : Design and Philosophy

ATT&CK Use Cases : The process of assessing the security of the technology by applying cyber threat intelligence according to different types of attackers. This helps us to understand the lifecycle and ability of mitigation for a team, ATT&CK can be used to make tools and recreate various adversary scenarios according to their different profile. This way we can understand the level of our security plans. Red team usually finds a way to break the system or have control on it without being noticed.

By going beyond analyzing traditional ways of investigating malware or viruses through signature , we can use behavioral activity to understand if something suspicious or unusual activities are going on. This won't be achieved by simple tools but advanced threat analysis tools can detect the unusual activity which really depends on the adversary and his/her way of manipulating the system. We can also analyze previous patterns and behaviors of adversaries to use it in future as a detection technique .

A Defense Gap assessment can be useful to analyze the security and defenses of the system which may include known exploits or privilege escalation risk.

Always make sure that all the users have minimum and enough permission for their work/task and keep all the systems isolated so that if one gets compromised others will be safe.

The SOC team should be tested against known popular attacks by the red team to see how they respond and recover the system which would give us an idea about their skillset and response time. Cyber Threat Intelligence contains information about malware tools , behavior , and other indicators which associate threat. This can help analysts to identify common behaviors and available mitigations for quick response. It also includes various adversary profiles and their recorded behavior , Though we can't rely on ATT&CK totally as adversaries change their tactics and behavior often according to the situation.

ATT&CK Coverage : If you are a defender you can use ATT&CK to list all the attack techniques and possibility of them to be detected in your system , or if you are an offender you can choose your tool and assets according to your attack plan. Though this Framework is useful for defenders to generate and respond to alerts it's not a good idea to totally follow this Framework as it is , it really depends on your organization's systems and daily tasks . For example if ipconfig.exe is frequently used to check the network configurations or trouble shoot networks the ATT&CK system will alert you as an adversary was able to steal network information by this file which in your case might be totally safe and this can create useless alerts. Adversaries always change their ways and critical paths for attack which makes it difficult to predict or stop a future attack so it's impossible to list all attack techniques as they can't be known in advance.

Technology Domains : MITRE has defined 3 technological domains which mean that following assets or services can get compromised by attackers according to the scope of attack

Technology Domain	Compromisable Assets and services
Enterprise	Linux , Windows , MacOS , cloud services, SaaS etc
Mobile	Android , IOS , Saas

Tactical Objective : Tactics can show us what an adversary wants to achieve, maybe encrypt all the data and ask for money for a decryption key or send data to their servers , make the system unfunctional , spy on the activities going on etc. These tactics are treated as tags in MITRE to attach techniques or sub-techniques to specific tags.

Techniques and Sub-techniques : Techniques show us how an adversary may achieve a tactical objective like getting access , executing corrupted files etc. Avoiding these techniques and sub techniques can fail their tactical objective. Sub techniques can be classified as behaviors described by the technique .

D3FEND Framework

Hardening :

- 1) Application Hardening : Includes steps like Dead code elimination and pointer authentication these steps makes an executable application resistant to various exploits and vulnerabilities.
- 2) Credential Hardening : Includes steps like Biometric Authentication strong password policy which help us to modify system and network property for better security.
- 3) Message Hardening : Includes steps like Message authentication , Message encryption which ensures confidentiality and integrity.
- 4) Platform Hardening : Includes steps like Boot loader authentication , local file permissions which make them more hard to exploit

Detect :

- 1) File Analysis : Includes steps like Dynamic analysis , file content rules which help us to identify malware and trojans by finding suspicious signatures or metadata.
- 2) Identifier Analysis : Includes steps like Homoglyph detection and URL analysis which helps us to identify different ip addresses , urls, domain names to check their records or reputation.
- 3) Message Analysis : Includes Sender MTA reputation analysis and sender reputation analysis which help us to verify the authority messages and email sent by reverse checking.
- 4) Network Traffic Analysis : Includes network administrator analysis , DNS traffic analysis which provides an informative observation on all networks to check activities.

- 5) Platform Monitoring : Includes Firmware behavior analysis , operating system monitoring which observes all the hardware and low level components to detect suspicious activities .
- 6) Process Analysis : Includes File Access pattern analysis , process spawn analysis which are useful to observe all the processes running in an application and can detect unknown or suspicious processes.
- 7) User Behavior Analysis : Authentication event Thresholding , local account monitoring which can let us know if any user's system or credentials are compromised so there are suspicious activities.

Isolate :

- 1) Execution Isolation : Includes Executable allow listing , Hardware based process isolation which help us to monitor system resources and make sure that no process is taking unusual amounts of system resources.
- 2) Network Isolation : Includes DNS allow listing , Encrypted tunnels which makes sure that network host does not take unusual network resources.

Deceive :

- 1) Decoy environment : Includes connected honeypots , Integrated Honeypots which helps us to deceive attackers target by attacking them to vulnerable honeypots and collecting their attacking behavior info.
- 2) Decoy object : Includes Decoy files and Decoy network assets that act as legitimate company assets to deceive attackers which also records info about attackers and their behavior pattern.

Evict :

- 1) Credential Eviction : Includes Accounting locking and authentication cache invalidation these are steps like removing compromised credentials and taking further steps like rolling credentials after every week.
- 2) Process Eviction : This includes process termination which is helpful if an unwanted or unknowing process starts to damage the system it can be terminated and it's suspicious behavior can be recorded.

To know more about the defend framework it is recommended to visit their official page which includes all the content required.

Official page link : <https://d3fend.mitre.org/>